



Security Assessment



Item 15 Internal Report

August 2026

Prepared for ether.fi



Disclaimer

This document is intended for **internal** use only.



Initial Commit Hash	Final Commit Hash
56719bb523	27385346

Protocol Scope

- src/libraries/SafeErc1271Lib.sol
- src/safe/EtherFiSafe.sol
- src/safe/EtherFiSafeErrors.sol
- src/safe/MultiSig.sol

Informational Issues

I-01. Stipend-based ETH transfers revert

Description: The new `receive()` does storage reads, a provider pause check, a WETH deposit, and event emission. That exceeds the 2,300 gas stipend from `transfer/send`. Only the WETH sender gets the cheap early return.

Recommendation: Consider returning earlier if the gas passed is limited.

Customer's response: Fixed in [48cfa2d61](#)

Fix review: Partially fixed. If less gas is sent than necessary for wrapping, the function returns without further execution. However, we noted that previous to this scope, raw `transfer/send` operations would revert anyway due to proxy execution.

I-02. wrapEth racing condition with OpenOcean module

Description: `OpenOceanSwapModule` enables safes to trade native ETH in the swap function. Since the `wrapEth` function is permissionless, a griever can front-run a safe's swap and consume all the native ETH of the safe, blocking the swap.

Recommendation: Consider introducing some access control on the `wrapEth` function.

Customer's response: Acknowledged



I-03. wrapEth racing condition with EtherFiStakeModule module

Description: The `EtherFiStakeModule` allows safes to deposit into the `L2SyncPool`. Similar to I-02, if a safe contains latent ETH and the safe owner intends to use it for deposit, a 3rd-party actor can call `wrapETH()` to convert the native ETH to WETH, griefing the call.

Recommendation: Consider introducing some access control on the `wrapEth` function.

Customer's response: Acknowledged



I-04. `receive()` performs a WETH deposit and emits a false `EthWrapped` event for zero-value calls

Description: When the `receive()` function fires with zero-value being sent, it still attempts to wrap into ETH and emits the `EthWrapped` event which is slightly misleading.

Recommendation: No-op for zero-value calls.

Customer's response: Fixed in [48cfa2d61](#)

Fix review: Fix confirmed.



I-05. Incorrect comment in LendGateway following code changes

Description: `LendGateway.sol` contains the comment "EtherFiSafe never implements ERC-1271 isValidSignature." However, this is not true following this PR. EtherFi safes now implement ERC-1271 but are secure in that they do not allow users to bypass critical functionality, e.g. by setting an arbitrary Aave spoke position manager via `setUserPositionManagerWithSig`.

Recommendation: Update the comment to reflect the latest changes.

Customer's response: Fixed in [4dbc7fe4a7](#)

Fix review: Fix confirmed.



I-06. wrapEth griever could prevent AaveV3 ETH repayment

Description: `SaveV3Module` checks the Safe's native balance and forwards that ETH to the wrapped-token gateway. Since the wrapEth function is permissionless, a griever can front-run a repayment, potentially delaying repayment.

Recommendation: Consider introducing some access control on the `wrapEth` function.

Customer's response: Acknowledged.

Disclaimer

Even though we hope this information is helpful, we provide no warranty of any kind, explicit or implied. The contents of this report should not be construed as a complete guarantee that the contract is secure in all dimensions. In no event shall Certora or any of its employees be liable for any claim, damages, or other liability, whether in an action of contract, tort, or otherwise, arising from, out of, or in connection with the results reported here.

About Certora

Certora is a Web3 security company that provides industry-leading formal verification tools and smart contract audits. Certora's flagship security product, Certora Prover, is a unique SaaS product that automatically locates even the most rare & hard-to-find bugs on your smart contracts or mathematically proves their absence. The Certora Prover plugs into your standard deployment pipeline. It is helpful for smart contract developers and security researchers during auditing and bug bounties.

Certora also provides services such as auditing, formal verification projects, and incident response.